

M3 – Autenticación y Gestión de Sesiones

Objetivo: Comprender los riesgos en la autenticación y gestión de sesiones, las vulnerabilidades más comunes y cómo implementar soluciones seguras utilizando estándares modernos como JWT y OAuth.

José Picón

INTRODUCCIÓN A LA AUTENTICACIÓN Y GESTIÓN DE SESIONES

¿Qué es la autenticación?

- 0 Proceso de **verificar la identidad** de un usuario en un sistema.
- 0 Métodos comunes: **Contraseñas, biometría, autenticación multifactor (MFA).**



INTRODUCCIÓN A LA AUTENTICACIÓN Y GESTIÓN DE SESIONES

¿Qué es la gestión de sesiones?

- 0 Mecanismo para **mantener el estado de autenticación** de un usuario después del inicio de sesión.
- 0 Depende de **cookies, tokens y mecanismos de almacenamiento seguro**.



INTRODUCCIÓN A LA AUTENTICACIÓN Y GESTIÓN DE SESIONES

Problemas comunes en autenticación y sesiones

- 0 Contraseñas débiles o filtradas.
- 0 Secuestro de sesión mediante ataques como CSRF o XSS.
- 0 Uso inadecuado de cookies y tokens inseguros.



AUTENTICACIÓN

¿Qué es Broken Authentication?

Definición

Se produce cuando **un sistema de autenticación es vulnerable**, permitiendo a atacantes acceder a cuentas sin credenciales válidas.

Consecuencias

- Suplantación de identidad.
- Acceso no autorizado a cuentas.
- Fugas de datos confidenciales.

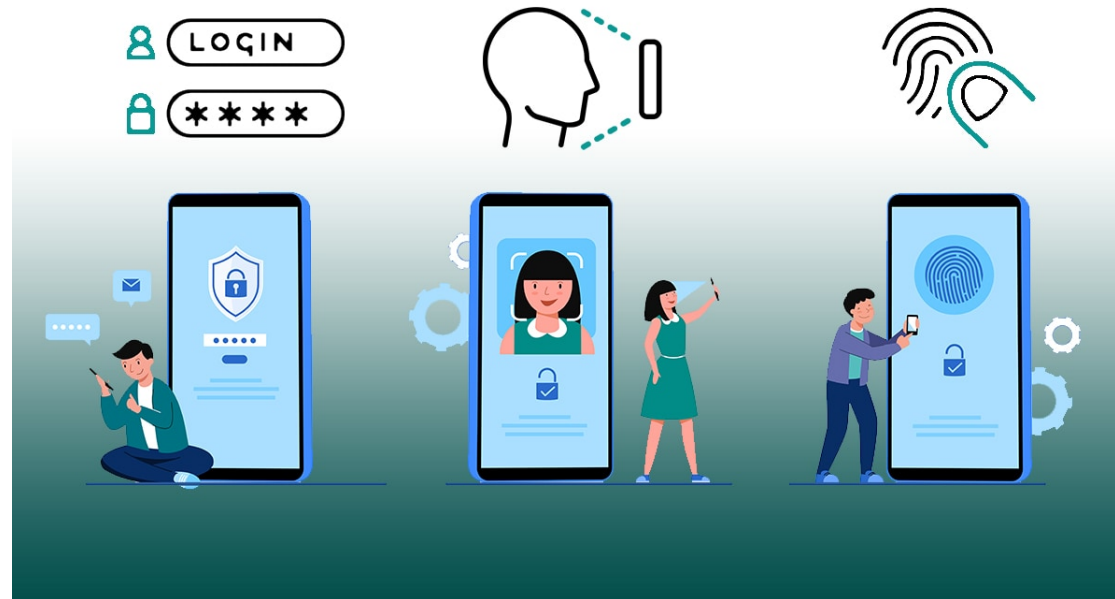


AUTENTICACIÓN

¿Qué es Broken Authentication?

Ejemplos de vulnerabilidades

- Uso de **contraseñas débiles o predecibles**.
- Almacenamiento inseguro de credenciales (*texto plano o cifrados débiles*).
- Implementación incorrecta de **autenticación multifactor (MFA)**.



AUTENTICACIÓN

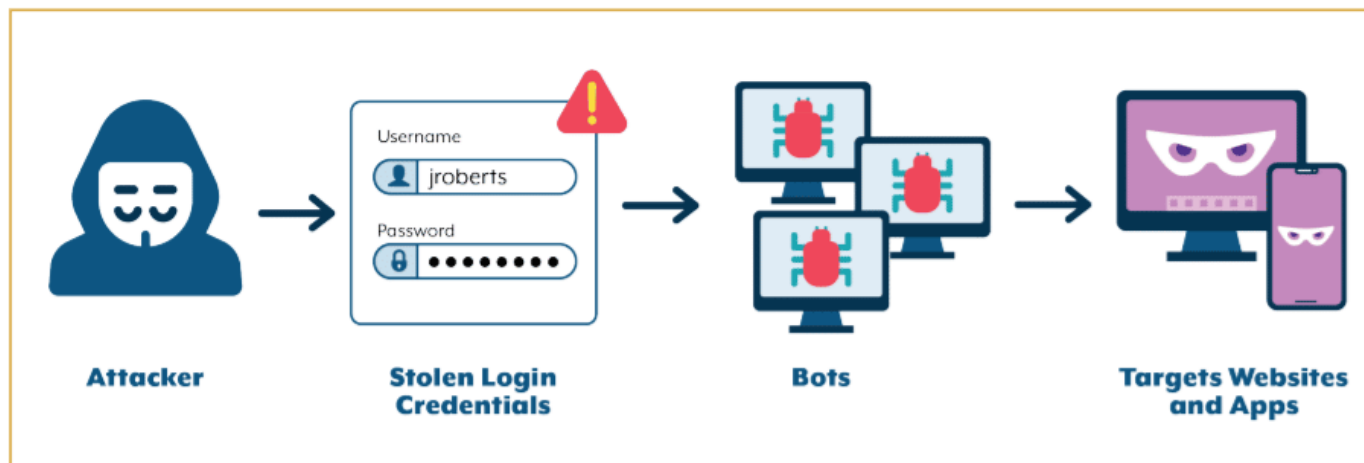
Ejemplo de Ataque – Fuerza Bruta y Credential Stuffing

Fuerza Bruta

- Un atacante prueba múltiples combinaciones de contraseñas hasta encontrar la correcta.
- **Ejemplo de herramienta:** Hydra, Burp Suite, John The Ripper.

Credential Stuffing

- Uso de **credenciales filtradas** de otros sitios para acceder a cuentas.



AUTENTICACIÓN

Ejemplo de Ataque – Fuerza Bruta y Credential Stuffing

Ejemplo de ataque:

- Usuario usa la misma contraseña en varios sitios.
- Atacante obtiene credenciales filtradas y accede a otros servicios.

Mitigación

- Imponer políticas de contraseñas seguras (*longitud mínima, complejidad*).
- Implementar autenticación multifactor (MFA).
- Usar CAPTCHA y bloquear intentos de inicio de sesión sospechosos.

AUTENTICACIÓN

Ejemplo de Ataque - Enumeración de Usuarios

¿Cómo funciona?

- Un atacante prueba direcciones de correo electrónico en una página de inicio de sesión y detecta qué usuarios existen según la respuesta del servidor.

Mitigación

- Usar respuestas genéricas en el login ("*Credenciales incorrectas*").
- Limitar intentos fallidos de inicio de sesión.

ACTIVIDAD

M3-A1-Explotación y Mitigación de Broken Authentication

Tema: Ataques contra autenticación débil

Objetivo: Explorar cómo una mala autenticación permite acceso no autorizado y aplicar soluciones

GESTIÓN DE SESIONES

¿Qué es la Gestión de Sesiones?

Importancia

- Mantiene **la identidad del usuario autenticado** mientras navega por la aplicación.
- Utiliza **cookies, tokens o almacenamiento en servidor**.

Riesgos comunes

- Secuestro de sesión (*Session Hijacking*) mediante XSS o MITM.
- Fijación de sesión (*Session Fixation*) reutilizando identificadores de sesión.
- Uso de cookies inseguras (*sin atributos HttpOnly, Secure o SameSite*).

GESTIÓN DE SESIONES

Mejores Prácticas en Gestión de Sesiones

Cookies seguras

- Atributo **HttpOnly**: *Evita acceso desde JavaScript.*
- Atributo **Secure**: *Solo permite envío por HTTPS.*
- Atributo **SameSite**: Previene ataques CSRF.

Regeneración de ID de sesión

- Cambiar el identificador de sesión después de autenticación para evitar *Session Fixation*.

Expiración y cierre de sesión

- Establecer **tiempo de expiración corto** en sesiones inactivas.
- Forzar **cierre de sesión en múltiples dispositivos** si se detectan accesos sospechosos.

ACTIVIDAD

M3-A2-Explotación y Mitigación de Gestión Insegura de Sesiones

Tema: Secuestro de sesiones

Objetivo: Identificar riesgos en la gestión de sesiones y mitigarlos

JSON WEB TOKEN – JWT

¿Qué es JWT y cómo funciona?

Definición

- **JSON Web Token (JWT)** es un estándar abierto (RFC 7519) que define un método compacto y seguro para representar información entre partes como un objeto JSON firmado digitalmente. Se utiliza comúnmente para autenticación y autorización en aplicaciones web.

Componentes

- **Header:** Algoritmo de firma y tipo de token.
- **Payload:** Información del usuario (*claims*).
- **Signature:** Firma digital con clave secreta o clave pública/privada.

Ejemplo de JWT

```
{  
  "alg": "HS256",  
  "typ": "JWT"  
}.  
{  
  "sub": "user123",  
  "role": "admin"  
}.  
SIGNATURE
```


JSON WEB TOKEN – JWT

Riesgos de JWT y Cómo Mitigarlos

Riesgos

- Uso de algoritmos débiles (*None, HS256 sin clave segura*).
- JWT sin expiración permite ataques de reutilización.
- Exposición de información sensible en el payload.

Mitigación

- Usar **RS256** en vez de **HS256** para mayor seguridad.
- Incluir expiración (*exp*) en el token.
- No almacenar información sensible en el payload.

ACTIVIDAD

M3-A3-Manipulación de JWT y cómo protegerlo

Tema: Seguridad en JSON Web Tokens (JWT)

Objetivo: Explorar cómo JWT puede ser manipulado y aplicar protección

OAuth Y AUTENTICACIÓN FEDERADA

Introducción a OAuth 2.0

¿Qué es OAuth?

- Protocolo de autorización que permite a los usuarios acceder a recursos sin compartir contraseñas.
- Usado por Google, Facebook y GitHub para autenticación con terceros.

Flujos de Oauth

- **Authorization Code Flow:** Más seguro, usa redirecciones y tokens temporales.
- **Implicit Flow:** Menos seguro, entrega tokens directamente al cliente.

OAuth Y AUTENTICACIÓN FEDERADA

Diferencias entre OAuth y OpenID Connect

OAuth 2.0

- Enfoque en autorización.
- Permite acceso a recursos sin compartir credenciales.

OpenID Connect (OIDC)

- Extiende OAuth con autenticación.
- Incluye información del usuario (*id_token*).

Casos de uso

- OAuth: *Permitir que una app acceda a Google Drive.*
- OIDC: *Permitir login en una app con la cuenta de Google.*

ACTIVIDAD

M3-A4-Explotación y Mitigación de OAuth Inseguro

Tema: Implementación segura de OAuth 2.0

Objetivo: Identificar errores en la autenticación OAuth y mitigarlos